

Saxta Login Səhifəsi Necə İşləyir?

Hücumçu saxta admin panelinə istifadəçi adı və parol daxil edəndə, bu məlumatın addım-addım necə tutulub log faylına yazıldığıнын tam izahı.

1. Ümumi Mənzərə

Honeypot VM-də (192.168.50.10) işləyən saxta login səhifəsi əslində **heç kimi autentifikasiya etmir**. O, sadəcə bir tələdir: istifadəçi formu doldurub "Login" düyməsinə basanda, server bu məlumatı arxa planda qeyd edir və sonra istifadəçiyə eyni login səhifəsini yenidən göstərir — sanki heç nə baş verməyib kimi. Məqsəd budur ki, hücumçu hansı istifadəçi adı və parol kombinasiyalarını sınağını bilmədən öz "açarlarını" bizə göstərsin.

2. Sorğunun Həyat Dövrü (Request Flow)

1. Brauzerdə form doldurulur

İstifadəçi (hücumçu) `http://192.168.50.10` ünvanındakı formaya username və password yazıb submit edir.



2. HTTP POST sorğusu göndərilir

Brauzer bu məlumatı `Content-Type: application/x-www-form-urlencoded` formatında serverə göndərir.



3. Python server sorğunu qəbul edir

`fake_login.py` skriptindəki `do_POST()` funksiyası işə düşür.



4. Məlumat oxunur və ayrılır

`parse_qs()` funksiyası göndərilən mətndən `username` və `password` dəyərlərini çıxarır; `self.client_address[0]` isə göndərən IP ünvanını verir.



5. Log faylına yazılır

Tarix/vaxt, IP, istifadəçi adı və parol bir sətir kimi `/var/log/honeypot_web.log` faylının sonuna əlavə edilir (append).



6. Eyni səhifə geri qaytarılır

Server heç bir yoxlama aparmadan (parol düzdülmü, yoxdurmu — fərq etmir) yenidən login formunu göstərir. Hücümçü üçün nəticə həmişə "yenidən cəhd et" kimi görünür.

Diqqət: Addım 6-da heç bir `if password == "doğru_parol"` yoxlaması yoxdur — çünki bu səhifənin məqsədi giriş vermək deyil, sadəcə cəhdi qeydə almaqdır. Ona görə də istifadəçi doğru parolu da yazsa, səhv parolu da yazsa, nəticə eynidir.

3. Kodun izahı — fake_login.py

Skriptin əsas hissəsi aşağıdakı kimidir; hər sətirin nə etdiyi şərh olaraq göstərilib:

```
# Sorğunu emal edən sinif
class Handler(BaseHTTPRequestHandler):

    # Brauzer sadəcə səhifəni açanda (GET) çağırılır
    def do_GET(self):
        self.send_response(200)
        self.wfile.write(PAGE) # login formunu göstərir

    # İstifadəçi "Login" düyməsinə basanda (POST) çağırılır
    def do_POST(self):
        length = int(self.headers.get('Content-Length', 0))
        body = self.rfile.read(length).decode() # göndərilən data
        data = parse_qs(body) # username=...&password=... ayrılır

        user = data.get('username', [''])[0]
        pwd = data.get('password', [''])[0]
        ip = self.client_address[0] # göndərən IP-si

        # --- BURADA IP VƏ MƏLUMAT LOG FAYLINA YAZILIR ---
        with open(LOG, "a") as f:
            f.write(f"{datetime.now()} | IP={ip} | user={user} | pass={pwd}\n")

        self.send_response(200)
        self.wfile.write(PAGE) # eyni login formunu yenidən göstərir
```

Diqqət ediləcək əsas sətir `f.write(...)` sətiridir — məhz bu sətir hücumçunun IP ünvanını, cəhd vaxtını və yazdığı istifadəçi adı/parolu daimi olaraq fayla əlavə edir. `"a"` rejimi (append) sayəsində fayl hər dəfə sıfırlanmır, əksinə hər yeni cəhd əvvəlki sətirlərin altına əlavə olunur.

4. Log Faylının Formatı

Hər sətir bu strukturda yazılır:

SAHƏ	MƏNBƏ	NÜMUNƏ
Tarix/Vaxt	<code>datetime.now()</code>	2026-09-10 17:24:41
IP ünvanı	<code>self.client_address[0]</code>	192.168.50.20
İstifadəçi adı	Formdakı <code>username</code> sahəsi	admin

Real Nümunə — VM #2-dən gələn hücum sırasında yazılan sətirlər

Aşağıdakı sətirlər VM #2-də işlədilən `web_bruteforce.py` skriptinin honeypot-a göndərdiyi həqiqi cəhdlərin loq faylında necə görünəcəyinin nümunəsidir (bütün cəhdlər eyni hücumçu IP-sindən, 192.168.50.20-dən gəlib):

```
2026-09-10 17:24:41.183 | IP=192.168.50.20 | user=root | pass=letmein 2026-09-10 17:24:42.021 |  
IP=192.168.50.20 | user=admin | pass=admin123 2026-09-10 17:24:42.933 | IP=192.168.50.20 | user=test |  
pass=backup123 2026-09-10 17:24:43.877 | IP=192.168.50.20 | user=test | pass=letmein 2026-09-10 17:24:44.652  
| IP=192.168.50.20 | user=admin | pass=backup123 2026-09-10 17:24:45.410 | IP=192.168.50.20 | user=root |  
pass=password 2026-09-10 17:24:46.288 | IP=192.168.50.20 | user=admin | pass=password 2026-09-10  
17:24:47.055 | IP=192.168.50.20 | user=root | pass=admin123 2026-09-10 17:24:47.902 | IP=192.168.50.20 |  
user=test | pass=backup123 2026-09-10 17:24:48.671 | IP=192.168.50.20 | user=root | pass=123456 2026-09-10  
17:24:49.534 | IP=192.168.50.20 | user=backup | pass=123456 2026-09-10 17:24:50.298 | IP=192.168.50.20 |  
user=test | pass=admin123
```

Bu sətirlərə diqqətlə baxsaq: **hər sətirin IP hissəsi eynidir (192.168.50.20)** — çünki bütün cəhdlər eyni hücumçu maşınından gəlib. Real bir hücumda fərqli IP-lər görünseydi, bu, birdən çox mənbədən (məsələn, botnet) gələn hücumu göstərərdi. Məhz bu "kim, nə vaxt, nə cəhd etdi" məlumatı log-parsing skripti üçün xammal rolunu oynayır — növbəti mərhələdə bu sətirlər sayılıb, ən çox təkrarlanan IP və istifadəçi adları çıxarılıb dashboard-da göstəriləcək.

5. Niyə Bu Metod Təhlükəsizdir?

- **Real parol yoxlanmır:** Sistemdə əslində mövcud olan istifadəçilərin (admin, backup, test) parollarına qarşı heç bir müqayisə edilmir — bu login forması onlarla heç bir əlaqədə deyil, tamamilə ayrı, saxta bir görüntüdür.
- **Heç vaxt "uğurlu giriş" olmur:** Nə yazılsa yazılsın, nəticə dəyişmir — bu, hücumçunu çaşdırıb daha çox cəhd etməyə təhrik edir, beləliklə daha çox məlumat toplanır.
- **İzolə şəbəkədə işləyir:** Bu bütün sistem VMnet1 (host-only) şəbəkəsində olduğu üçün toplanan IP-lər yalnız lab daxilindəki maşınlarla (192.168.50.0/24) aiddir, real internet istifadəçilərinə yox.

Qeyd: Bu texnika yalnız öz nəzarətimizdə olan, izolə edilmiş lab mühitində istifadə olunur. Real internetə açıq bir honeypot qurmaq üçün əlavə hüquqi və təhlükəsizlik tədbirləri (icazə, monitoring, məsuliyyət həddləri) tələb olunur.